Care Access Navigator

Compliance 1 — Task 5: Legal & Ethical Implementation

Legal requirements research with compliance obligations matrix, ethical framework applied to a compliance decision, compliance risk assessment, and a documented compliance incident

Prepared by:	Akhila Chennamaneni, GRC Analyst (author)
Organization:	HealthLine Regional Medical Center — Care Access Navigator (CAN)
Industry:	Health care (acute and outpatient care) that also accepts card payments
Jurisdiction:	United States federal law; New York State (assumed location)
Date:	October 13, 2026

Disclaimer: This is a student analysis prepared for coursework. It summarizes primary sources accurately to the best of the author's knowledge but is not legal advice; HealthLine would confirm obligations with counsel.

1. Legal Requirements Research

Research started from primary sources (statutes, regulations and the PCI standard itself), then used regulator guidance to interpret them. Each source was checked for currency (latest amendment or version).

Source	Type	Why it applies to HealthLine / CAN
45 CFR Parts 160 and 164 (HIPAA Privacy, Security, Breach Notification, Enforcement Rules)	Federal regulation (eCFR)	Covered entity handling ePHI
HITECH Act, Pub. L. 111-5, Div. A Title XIII (2009)	Federal statute	Breach notification; direct BA liability; tiered penalties
21st Century Cures Act; 45 CFR Part 171 (information blocking)	Federal statute / regulation	Provider must not unreasonably interfere with patient access to electronic health information
PCI DSS v4.0.1 (PCI Security Standards Council, June 2024)	Industry standard, contractually binding	Merchant accepting card payments in the Billing App
NY General Business Law §899-aa (breach notification) and §899-bb (SHIELD data security)	State statute	NY residents' private information (incl. medical data); HIPAA-compliant entities deemed compliant with §899-bb
10 NYCRR §405.10; NY Public Health Law §18	State regulation / statute	Hospital medical-record content and retention; patient access to records
HHS OCR guidance; NIST SP 800-66r2 (2024); NIST SP 800-30r1	Regulator / standards guidance	How to implement and assess HIPAA Security Rule safeguards and risk

Compliance obligations matrix

ID	Obligation	Citation	Owner	Control / evidence	Frequency
OB-01	Conduct an accurate and thorough risk analysis; manage risk	45 CFR 164.308(a)(1)(ii)(A)–(B)	Security Officer	Annual risk analysis; risk register	Annual + on change
OB-02	Designate privacy and security officials	164.530(a); 164.308(a)(2)	COO	Appointment letters	On vacancy
OB-03	Limit access to minimum necessary; role-based access	164.502(b); 164.308(a)(4); PCI 7.2	IAM Analyst	AC-01; access reviews	Quarterly
OB-04	Unique user IDs and person/entity authentication (MFA for CDE)	164.312(a)(2)(i), (d); PCI 8.2, 8.4	IAM Analyst	Keycloak config; F-01 remediation	Continuous
OB-05	Audit controls and activity review; retain CDE logs 12 months	164.312(b); 164.308(a)(1)(ii)(D); PCI 10.4–10.5	Security Officer	LOG-01; log platform	Daily review
OB-06	Encrypt ePHI and PAN in transit	164.312(e)(1); PCI 4.2.1	Security Officer	ENC-01; Azure Policy	Continuous
OB-07	Train all workforce members; security awareness	164.530(b); 164.308(a)(5); PCI 12.6	Privacy Officer	LMS records	At hire + annually
OB-08	Sanction workforce members who violate policy	164.530(e); 164.308(a)(1)(ii)(C)	HR	Sanctions log	Per incident
OB-09	Business associate agreements before sharing PHI	164.308(b); 164.504(e)	Vendor Manager	BAA inventory	Per vendor
OB-10	Notify individuals of breach without unreasonable delay, ≤ 60 days	164.404	Privacy Officer	Incident record; letters	Per breach
OB-11	Notify HHS (≥ 500: within 60 days; < 500: annual log within 60 days of year end)	164.408	Privacy Officer	OCR portal receipt	Per breach / annual
OB-12	Notify NY Attorney General when HHS is notified (within 5 business days)	NY GBL 899-aa	Privacy Officer	AG submission	Per breach
OB-13	Provide patients timely access to their records; avoid information blocking	164.524; 45 CFR 171; NY PHL 18	HIM Director	Request log	Per request
OB-14	Retain HIPAA documentation 6 years; hospital records per state law	164.316(b)(2)(i); 164.530(j); 10 NYCRR 405.10	GRC Analyst	Retention schedule (Task 4)	Continuous
OB-15	Annual PCI DSS validation (SAQ) and quarterly ASV scans	PCI DSS 12.4; 11.3.2; acquirer contract	Security Officer	SAQ, AOC, ASV reports	Annual / quarterly

Citations without a prefix refer to 45 CFR (HIPAA).

2. Ethical Framework Applied to a Compliance Decision

Scenario. During the incident in Section 4, investigators confirm that a long-serving billing specialist looked up a neighbour's account three times. The patient is a well-known local donor. A senior manager suggests handling it quietly with a verbal warning and *not* treating it as a reportable breach, because notification could embarrass the donor and the hospital before its annual fundraising gala.

Decision-making process

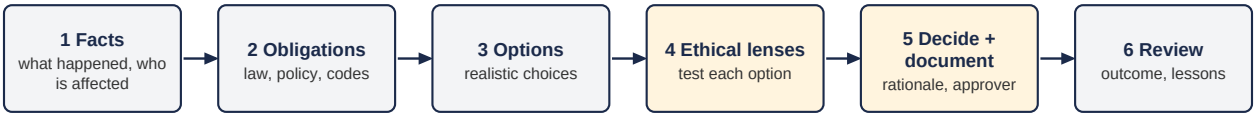

Figure 1. Six-step ethical decision-making process used by the Compliance & Privacy Committee.

Lens	Question asked	Option A: quiet warning, no notification	Option B: breach process, notify, consistent sanction
Legal / duty (deontological)	What do law and our duties require?	Violates §164.404 if breach criteria are met; ignores sanctions policy	Meets HIPAA and NY duties
Consequences (utilitarian)	Which option produces the best outcomes for all affected?	Short-term comfort; high risk of later discovery, larger penalties, loss of trust	Short-term embarrassment; protects patient, workforce culture and institution long term
Rights	Whose rights are at stake?	Patient denied the right to know and to protect themselves	Patient's right to notice respected
Justice / fairness	Are people treated consistently?	Senior or valued staff treated more leniently	Same rule for every workforce member and patient
Virtue / professional codes	What would a trustworthy professional do? (AHIMA Code; ISC2 Code canon 'act honorably, honestly, justly')	Concealment conflicts with honesty and the duty to protect privacy	Integrity and accountability demonstrated

Decision and rationale

Option B is chosen. Every lens favours it, and Option A would turn a single impermissible access into an organizational cover-up. The donor's status is not a lawful factor in the breach assessment. The manager's concern is addressed by careful, respectful communication with the patient and by timing nothing around the gala.

Decision record field	Entry
Decision ID / date	ETH-2026-004 / 2026-11-20

Decision record field	Entry
Decision	Apply the standard breach risk assessment and notification process; apply the sanctions policy consistently
Decided by	Privacy Officer, with CCO concurrence; reported to the Compliance & Privacy Committee
Alternatives rejected	Option A (quiet warning without notification) — unlawful and unfair
Dissent recorded	Senior manager's concern about reputational timing noted; resolved through communication plan
Retention	Kept with the incident file for 6 years (§164.530(j))

3. Compliance Risk Assessment

Methodology: NIST SP 800-30r1, using the same 5 × 5 likelihood × impact scale as the capstone risk register so the results are comparable. Impact considers regulatory penalties, contractual (card-brand) consequences, patient harm, operations and reputation; the highest applicable category sets the score.

Score	Likelihood (12 months)	Impact
5	Almost certain (> 90%)	Severe: OCR investigation with penalties; loss of ability to accept cards; patient harm
4	Likely (50–90%)	Major: reportable breach; contractual fines; significant media attention
3	Possible (20–50%)	Moderate: non-compliance found in audit; corrective action plan
2	Unlikely (5–20%)	Minor: internal policy breach, no external reporting
1	Rare (< 5%)	Negligible

ID	Compliance risk	L	I	Inherent	Existing controls	Res. L×I	Treatment	Owner
CR-01	Workforce member views ePHI without a work need (snooping)	4	4	**Critical** (16)	RBAC + client scopes; event logging	3×4=12	Mitigate: VIP/same-surname monitoring rule; training M2	Privacy Officer
CR-02	Credential compromise because MFA is not enforced	4	5	**Critical** (20)	Password policy; alerting	2×5=10	Mitigate: enforce MFA + lockout (F-01, F-02)	IAM Analyst
CR-03	CDE logs not retained 12 months (PCI 10.5.1)	5	3	**Critical** (15)	90-day native retention	1×3=3	Mitigate: central log store (F-03)	Security Officer
CR-04	Breach notification later than 60 days	2	5	**High** (10)	IR playbook; Privacy Officer	1×5=5	Mitigate: notification checklist and clock in incident system	Privacy Officer

ID	Compliance risk	L	I	Inherent	Existing controls	Res. L×I	Treatment	Owner
CR-05	Vendor handles PHI without a BAA	3	4	**High** (12)	Contract review	2×4=8	Mitigate: BAA inventory and onboarding gate	Vendor Manager
CR-06	Payment-page script tampering exposes card data (PCI 6.4.3/11.6.1)	2	5	**High** (10)	Processor-hosted fields	2×3=6	Mitigate + transfer: script inventory, change detection; processor liability	Security Officer
CR-07	Workforce not trained before accessing ePHI	3	3	**Moderate** (9)	Onboarding checklist	2×3=6	Mitigate: LMS completion gate before role assignment	Privacy Officer
CR-08	Information-blocking complaint over slow patient access	2	3	**Moderate** (6)	Patient Portal	2×2=4	Accept with monitoring of request turnaround	HIM Director

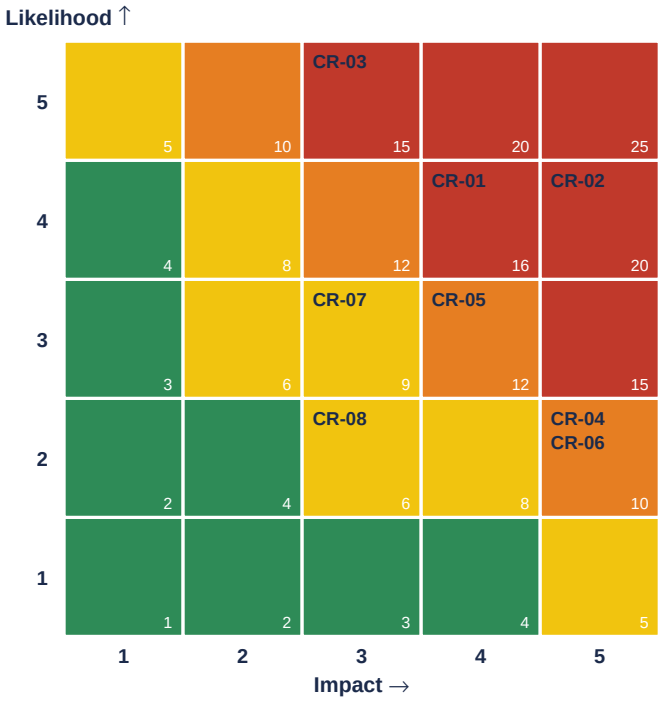

Figure 2. Inherent compliance risk heat map (likelihood × impact).

Treatment recommendations

- **Mitigate first** the two Critical risks (CR-01, CR-02) — both are driven by authentication and monitoring gaps already in the remediation plan (Task 3).
- **Transfer** part of CR-06 through the PCI-validated processor contract and cyber insurance; keep script monitoring in house.

- **Accept** CR-08 at Moderate-Low with a monthly turnaround metric; the Program Sponsor signs the acceptance.
- No risk is **avoided** outright: card payments and patient portal access are core services.

4. Compliance Incident: Unauthorized Access to Patient Information

> **Scenario:** This is a tabletop scenario built on the real Care Access Navigator controls; dates are scenario dates. It complements the technical incident INC-20261008-01 from CloudSec1 Criterion 6.

Field	Detail
Incident ID	PRIV-2026-007
Discovered	2026-11-18 09:40, during the daily log review (control LOG-01)
Summary	A Billing-role user opened one patient's account in the Billing App three times over two days with no billing task assigned. The record shows visit dates and diagnosis codes (ePHI). No card data is involved.
Detection	Keycloak event log + Billing App audit trail; flagged by the 'same surname / same street' review heuristic
Individuals affected	1 (New York resident)

Classification

Severity	Criteria (adapted from the CAN incident playbook)	Applies?
SEV-1 Critical	Confirmed breach ≥ 500 individuals, exfiltration, or ransomware	No
SEV-2 High	Confirmed unauthorized access to ePHI or CHD, < 500 individuals	**Yes**
SEV-3 Medium	Suspected access; no ePHI confirmed; policy violation with exposure	—
SEV-4 Low	Policy deviation, no data exposure	—

Category: **privacy incident — impermissible use by a workforce member** (insider, intentional). Frameworks engaged: HIPAA Privacy and Breach Notification Rules; NY GBL §899-aa. PCI DSS not engaged.

HIPAA breach risk assessment (45 CFR 164.402(2))

Factor	Assessment
1 Nature and extent of PHI	Name, address, visit dates, diagnosis codes — sensitive health information
2 Unauthorized person	Workforce member bound by confidentiality, but acting for personal reasons
3 Actually acquired or viewed	Yes — viewed three times (audit trail); no evidence of printing or export
4 Extent risk mitigated	Access removed same day; written attestation of non-disclosure obtained; device check found nothing

Factor	Assessment
Conclusion	**Low probability of compromise cannot be demonstrated** (intentional viewing of sensitive data) → presumed **breach of unsecured PHI** affecting 1 individual

Reporting

Recipient	Requirement	Deadline	Action / status
Patient	164.404 written notice (what happened, PHI involved, steps to take, what HealthLine is doing, contact)	Without unreasonable delay; ≤ 60 days from 2026-11-18	Letter sent 2026-12-02 (day 14)
HHS OCR	164.408(c): breaches < 500 logged and reported annually	Within 60 days after end of 2026 (by 2027-03-01)	Added to 2026 breach log; submit via OCR portal by 2027-02-15
Media	164.406 only if > 500 residents of a state	Not required	—
NY Attorney General	GBL 899-aa: copy of HHS notification within 5 business days of notifying HHS	≤ 5 business days after HHS submission	Scheduled with HHS submission
Internal	Compliance & Privacy Committee; Board committee summary	Next meeting / quarterly	Reported 2026-11-25

Timeline and follow-up actions

Date	Event / action	Owner
2026-11-18	Detected in daily log review; Security Analyst opens PRIV-2026-007; Privacy Officer notified within 1 hour	Security Analyst
2026-11-18	Billing role removed from the user's account; evidence preserved (hashed log export)	IAM Analyst
2026-11-19	Interview; attestation of non-disclosure; HR suspension pending review	Privacy Officer, HR
2026-11-20	Four-factor assessment: breach; ethics decision ETH-2026-004 recorded	Privacy Officer
2026-12-02	Patient notification letter mailed	Privacy Officer
2026-12-05	Sanction applied per policy (consistent with prior cases); documented	HR
2026-12-15	Corrective actions: targeted access review of all Billing-role users; M2 refresher for Billing team; new monitoring rule for VIP / related-party lookups	IAM, Privacy, Security
2027-02-15	Submit 2026 breach log to HHS; copy to NY AG within 5 business days	Privacy Officer
Ongoing	Include the disclosure in any accounting of disclosures requested (164.528); retain incident file 6 years	Privacy Officer

Lessons learned

- Role-based access worked as designed — the user stayed inside the Billing App — but RBAC cannot detect *why* a record is opened; behaviour-based monitoring (CR-01 treatment) is required.
- Daily log review (finding F-05) is what caught this; it must be resourced and evidenced.
- Pre-written notification templates and a deadline tracker kept the response well inside 60 days.

Summary

HealthLine's legal obligations are documented with primary-source citations in a fifteen-item obligations matrix; a structured ethical framework was applied to a realistic pressure-to-conceal scenario and the decision was recorded; compliance risks were assessed with the NIST SP 800-30 method and given treatment decisions; and a privacy incident was classified, assessed under the HIPAA four-factor test, reported to the right parties within legal deadlines, and closed with corrective actions.